
DENNIS GUNAWAN



UMN
UNIVERSITAS
MULTIMEDIA
NUSANTARA

IF351 DATABASE SYSTEMS

09 DATABASE SECURITY



REVIEW:

TRANSACTION PROCESSING, CONCURRENCY, AND RECOVERY TECHNIQUES

- Transactions
- Concurrency
- Recovery Techniques
- Transaction Processing in MySQL

COURSE SUB LEARNING OUTCOMES (SUB-CLO)

- Sub-CLO 10
 - Students are able to explain database security (C2)
- Sub-CLO 11
 - Students are able to use SQL statements for managing users and privileges as well as creating views (C3)

OUTLINE

- Introduction to Database Security Issues
- Concept of a View
- Discretionary Access Control
- Mandatory Access Control
- Adding & Removing Users
- Granting, Passing On, & Revoking Privileges
- Creating, Updating, & Deleting Views

TYPES OF SECURITY

- Legal and ethical issues regarding the right to access certain information
 - Some information may be deemed to be private and cannot be accessed legally by unauthorized persons
- Policy issues at the governmental, institutional, or corporate level as to what kinds of information should not be made publicly available
 - Credit ratings
 - Personal medical records

TYPES OF SECURITY

- System-related issues such as the system levels at which various security functions should be enforced
 - Whether a security function should be handled at the physical hardware level, the operating system level, or the DBMS level
- The need in some organizations to identify multiple security levels and to categorize the data and users based on these classifications
 - For example, top secret, secret, confidential, and unclassified
 - The security policy of the organization with respect to permitting access to various classifications of data must be enforced

THREATS TO DATABASES

Loss of Integrity

- Database integrity → requirement that information be protected from improper modification (creation, insertion, modification, changing the status of data, deletion)
- Integrity is lost if unauthorized changes are made to the data by either intentional or accidental acts
- If the loss of system or data integrity is not corrected, continued use of the contaminated system or corrupted data could result in inaccuracy, fraud, or erroneous decisions

THREATS TO DATABASES

Loss of Availability

- Database availability → making objects available to a human user or a program to which they have a legitimate right

Loss of Confidentiality

- Database confidentiality → protection of data from unauthorized disclosure
- The impact of unauthorized disclosure of confidential information can range from violation of the Data Privacy Act to the jeopardization of national security
- Unauthorized, unanticipated, or unintentional disclosure could result in loss of public confidence, embarrassment, or legal action against the organization

TWO TYPES OF DATABASE SECURITY MECHANISMS

Discretionary Security Mechanisms

- These are used to grant privileges to users, including the capability to access specific data files, records, or fields in a specified mode (such as read, insert, update, or delete)

Mandatory Security Mechanisms

- These are used to enforce multilevel security by classifying the data and users into various security classes / levels and then implementing the appropriate security policy of the organization
- For example, a typical security policy is to permit users at a certain classification level to see only the data items classified at the user's own or lower classification level

CONTROL MEASURES

Access Control

- A security problem common to computer systems is that of preventing unauthorized persons from accessing the system itself, either to obtain information or to make malicious changes in a portion of the database
- The security mechanism of a DBMS must include provisions for restricting access to the database system as a whole
- This function is called access control and is handled by creating user accounts and passwords to control the login process by the DBMS

CONTROL MEASURES

Inference Control

- Statistical databases are used to provide statistical information or summaries of values based on various criteria
- Statistical database users such as government statisticians or market research firms are allowed to access the database to retrieve statistical information about a population but not to access the detailed confidential information about specific individuals
- Security for statistical databases must ensure that information about individuals cannot be accessed
- It is sometimes possible to deduce or infer certain facts concerning individuals from queries that involve only summary statistics on groups; consequently, this must not be permitted either

CONTROL MEASURES

Flow Control

- Prevents information from flowing in such a way that it reaches unauthorized users
- Channels that are pathways for information to flow implicitly in ways that violate the security policy of an organization are called covert channels

CONTROL MEASURES

Data Encryption

- Protects sensitive data that is transmitted via some type of communications network
- Encryption can be used to provide additional protection for sensitive portions of a database as well
- The data is encoded using some coding algorithm
- An unauthorized user who accesses encoded data will have difficulty deciphering it, but authorized users are given decoding or decrypting algorithms / keys to decipher the data

DATABASE SECURITY AND THE DBA

- Database administrator (DBA) is the central authority for managing a database system
- DBA has a DBA account in the DBMS, sometimes called a system or superuser account, which provides powerful capabilities that are not made available to regular database accounts and users

Types of actions

- **Account Creation**
This action creates a new account and password for a user or a group of users to enable access to the DBMS
- **Privilege Granting**
This action permits the DBA to grant certain privileges to certain accounts
- **Privilege Revocation**
This action permits the DBA to revoke / cancel certain privileges that were previously given to certain accounts
- **Security Level Assignment**
This action consists of assigning user accounts to the appropriate security classification level

DATABASE AUDITS

- If any tampering with the database is suspected, a database audit is performed, which consists of reviewing the log to examine all accesses and operations applied to the database during a certain time period
- When an illegal or unauthorized operation is found, the DBA can determine the account number used to perform the operation
- Database audits are particularly important for sensitive databases that are updated by many transactions and users, such as banking database that is updated by many bank tellers

TYPES OF DISCRETIONARY PRIVILEGES

Statement	User Privilege	Database Privilege	Table Privilege	Column Privilege
SELECT	✓	✓	✓	✗
INSERT	✓	✓	✓	✗
DELETE	✓	✓	✓	✓
UPDATE	✓	✓	✓	✓
REFERENCES	✓	✓	✓	✓
CREATE	✓	✓	✓	✗
ALTER	✓	✓	✓	✗
DROP	✓	✓	✓	✗
INDEX	✓	✓	✓	✓
CREATE TEMPORARY TABLES	✓	✓	✗	✗
CREATE VIEW	✓	✓	✗	✗
SHOW VIEW	✓	✓	✗	✗
CREATE ROUTINE	✓	✓	✗	✗

TYPES OF DISCRETIONARY PRIVILEGES

Statement	User Privilege	Database Privilege	Table Privilege	Column Privilege
ALTER ROUTINE	✓	✓	✗	✗
EXECUTE ROUTINE	✓	✓	✗	✗
LOCK TABLES	✓	✓	✗	✗
CREATE USER	✓	✗	✗	✗
SHOW DATABASES	✓	✗	✗	✗
FILE	✓	✗	✗	✗
PROCESS	✓	✗	✗	✗
RELOAD	✓	✗	✗	✗
REPLICATION CLIENT	✓	✗	✗	✗
REPLICATION SAVE	✓	✗	✗	✗
SHUTDOWN	✓	✗	✗	✗
SUPER	✓	✗	✗	✗
USAGE	✓	✗	✗	✗

CONCEPT OF A VIEW

A single table
that is derived from other tables

- These other tables can be base tables or previously defined views
- A view does not necessarily exist in physical form
- It is considered a virtual table, in contrast to base tables, whose tuples are actually stored in the database

SPECIFYING PRIVILEGES USING VIEWS

- The mechanism of views is an important discretionary authorization mechanism in its own right
- If the owner A of a relation R wants another account B to be able to retrieve only some fields of R , then A can create a view V of R that includes only those attributes and then grant SELECT on V to B
- The same applies to limiting B to retrieving only certain tuples of R
 - A view V' can be created by defining the view by means of a query that selects only those tuples from R that A wants to allow B to access

REVOKING PRIVILEGES

- In some cases, it is desirable to grant a privilege to a user temporarily
- The owner of a relation may want to grant the `SELECT` privilege to a user for a specific task and then revoke that privilege once the task is completed
- A `REVOKE` command is included for the purpose of canceling privileges

PROPAGATION OF PRIVILEGES USING THE GRANT OPTION

- Whenever the owner A of a relation R grants a privilege on R to another account B , the privilege can be given to B with or without the GRANT OPTION
- If the GRANT OPTION is given, this means that B can also grant that privilege on R to other accounts

MANDATORY ACCESS CONTROL

- The original Employee tuples

EMPLOYEE

Name	Salary	JobPerformance	TC
Smith U	40000 C	Fair S	S
Brown C	80000 S	Good C	S

- In some cases, it is possible to store a single tuple in the relation at a higher classification level and produce the corresponding tuples at a lower-level classification through a process known as **filtering**

- Appearance of Employee after filtering for classification C users

EMPLOYEE

Name	Salary	JobPerformance	TC
Smith U	40000 C	NULL C	C
Brown C	NULL C	Good C	C

- Appearance of Employee after filtering for classification U users

EMPLOYEE

Name	Salary	JobPerformance	TC
Smith U	NULL U	NULL U	U

MANDATORY ACCESS CONTROL

In other cases, it is necessary to store two or more tuples at different classification levels with the same value for the apparent key (the concept of **polyinstantiation**), where several tuples can have the same apparent key value but have different attribute values for users at different classification levels

Covert Channel

- User with security clearance C

```
UPDATE Employee  
SET JobPerformance = 'Excellent'  
WHERE Name = 'Smith';
```

- Polyinstantiation of the Smith tuple

EMPLOYEE

Name	Salary	JobPerformance	TC
Smith U	40000 C	Fair S	S
Smith U	40000 C	Excellent C	C
Brown C	80000 S	Good C	S

ADDING USERS

- To add new users in the catalog, MySQL uses the simple CREATE USER statement

```
CREATE USER 'username'@'hostname'  
IDENTIFIED BY 'password';
```

- Example

```
CREATE USER 'dennis'@'localhost'  
IDENTIFIED BY 'dennis';
```

- Show the contents of the users catalog view

```
SELECT host, user, password  
FROM mysql.user;
```


REMOVING USERS

- DROP USER statement is used to remove users from the system, and all their privileges are also removed automatically

```
DROP USER 'username'@'hostname';
```

- Example

```
DROP USER 'dennis'@'localhost';
```

CHANGING THE NAMES OF USERS

- The name of an existing SQL user can be later changed with the RENAME USER statement

```
RENAME USER 'username'@'hostname'  
TO 'new_username'@'new_hostname';
```

- Example

```
RENAME USER 'dennis'@'localhost'  
TO 'dennisgunawan'@'localhost';
```

CHANGING PASSWORDS

- Each user has the right to change his or her own password, or that of someone else, by using the SET PASSWORD statement

```
SET PASSWORD FOR 'username'@'hostname' = PASSWORD('password');
```

- Example

```
SET PASSWORD FOR 'dennisgunawan'@'localhost'  
= PASSWORD('dennisgunawan');
```

GRANTING PRIVILEGES

```
GRANT privileges | ALL PRIVILEGES  
ON table_name | [database_name.] * | *.*  
TO grantees;
```

```
GRANT SELECT  
ON actors  
TO 'dennis'@'localhost';
```

```
GRANT SELECT  
ON entertainment.*  
TO 'dennis'@'localhost';
```

```
GRANT CREATE USER  
ON *.*  
TO 'dennis'@'localhost';
```

```
GRANT INSERT, UPDATE  
ON actors  
TO 'dennis'@'localhost';
```

```
GRANT ALL PRIVILEGES  
ON *  
TO 'dennis'@'localhost';
```

```
GRANT CREATE, ALTER, DROP  
ON *.*  
TO 'dennis'@'localhost';
```

```
GRANT UPDATE (year, rank)  
ON movies  
TO 'dennis'@'localhost';
```

```
GRANT CREATE, ALTER, DROP, CREATE VIEW  
ON entertainment.*  
TO 'dennis'@'localhost';
```

PASSING ON PRIVILEGES

- A GRANT statement can be concluded with the WITH GRANT OPTION
- By using this statement, all users specified in the TO clause can themselves pass on the privilege (or part of the privilege) to other users, even if they are not the owner of it

```
GRANT SELECT, INSERT  
ON actors  
TO 'dennis'@'localhost'  
WITH GRANT OPTION;
```

- 'dennis'@'localhost'

```
GRANT INSERT  
ON actors  
TO 'rico'@'localhost';
```

REVOKING PRIVILEGES

- To withdraw privileges from a user without deleting that user from the users table, use the REVOKE statement

```
REVOKE privileges | ALL PRIVILEGES  
ON table_name | [database_name.] * | *.*  
FROM grantees;
```

- This statement has the opposite effect of the GRANT statement

```
REVOKE SELECT  
ON actors  
FROM 'dennis'@'localhost';
```

```
REVOKE GRANT OPTION  
ON actors  
FROM 'dennis'@'localhost';
```

CREATING VIEWS

- Views are created with the CREATE VIEW statement

```
CREATE [OR REPLACE] VIEW view_name [(column_list)]  
AS SELECT_statement  
[WITH CHECK OPTION];
```

- Example

```
CREATE VIEW movie_production  
AS SELECT name, year  
FROM movies;
```

```
SELECT name, year  
FROM movie_production;
```

```
CREATE OR REPLACE VIEW good_movies  
AS SELECT name, rank  
FROM movies  
WHERE rank > 6.5;
```

```
SELECT name, rank  
FROM good_movies;
```

COLUMN NAMES OF VIEWS

- The column names in a view default to the column names in the SELECT clause
- You can also explicitly define the column names of views
- Example

```
CREATE VIEW movie_production (movie_title, movie_year)  
AS SELECT name, year  
FROM movies;
```


UPDATING VIEWS

- If you extend the view definition using WITH CHECK OPTION, MySQL ensures that an unexpected effect does not arise
- Example

```
CREATE OR REPLACE VIEW good_movies
AS SELECT name, rank
FROM movies
WHERE rank > 6.5
WITH CHECK OPTION;
```
- If a view includes the WITH CHECK OPTION clause, all changes on the view with UPDATE, INSERT, and DELETE statements are checked for validity
 - An UPDATE statement is correct if the updated rows still belong to the (virtual) contents of the view
 - An INSERT statement is correct if the new rows belong to the (virtual) contents of the view
 - A DELETE statement is correct if the deleted rows belong to the (virtual) contents of the view

DELETING VIEWS

- DROP VIEW statement is used to delete a view

```
DROP VIEW [IF EXISTS] view_name;
```

- When IF EXISTS is specified, no error messages appear if the view that must be dropped does not exist

- Example

```
DROP VIEW movie_production;
```

```
DROP VIEW IF EXISTS good_movies;
```

RESTRICTIONS ON UPDATING VIEWS

- A view can be modified only if a one-to-one correspondence exists between the rows of the view and the rows of the underlying table
- The view formula should satisfy the following conditions
 - The SELECT clause may not contain DISTINCT
 - The SELECT clause may not contain aggregation functions
 - The FROM clause may not contain more than one table
 - The WHERE clause may not contain a correlated subquery
 - The SELECT statement may not contain a GROUP BY / HAVING clause
 - The SELECT statement may not contain an ORDER BY clause
 - The SELECT statement may not contain set operators

RESTRICTIONS ON UPDATING VIEWS

- In addition, the following restriction holds for the UPDATE statement
 - A virtual column may not be updated
 - $\text{age} = \text{CURRENT_DATE()} - \text{birth_date}$
- In addition, the following restriction holds for the INSERT statement
 - The SELECT clause must contain, from the table that is specified in the FROM clause, all columns in which the null value is not allowed or for which no default value is specified

SECURITY OF & THROUGH VIEWS

- A GRANT statement can refer not only to tables, but also to views
- Because privileges can also be granted for views, it is possible to provide users with access to only a part of a table or only to information derived or summarized from tables
- Example

```
CREATE VIEW good_movies  
AS SELECT name, rank  
FROM movies  
WHERE rank > 6.5;
```

```
GRANT SELECT  
ON good_movies  
TO 'dennis'@'localhost';
```

REFERENCES

- Elmasri, Ramez and Shamkant B. Navathe (2016), Fundamentals of Database Systems, 7th edition, Addison Wesley.
- Rick F. van der Lans (2007), SQL for MySQL Developers, Addison Wesley.
- Connolly, Thomas and Carolyn Begg (2015), Database Systems A Practical Approach to Design, Implementation, and Management, 6th edition, Pearson Education, ISBN 13: 978-1-292-06118-4, Essex, England.

NEXT WEEK:

FUNCTIONAL DEPENDENCIES AND NORMALIZATION FOR RELATIONAL DATABASES

- Functional Dependencies
- First Normal Form (1NF)
- Partial Dependency
- Second Normal Form (2NF)
- Transitive Dependency
- Third Normal Form (3NF)

```
SELECT *  
FROM WORLD  
WHERE SOMEONE  
LIKE '%YOU%';
```

```
EMPTY SET (0.00 SEC)
```

Vision

To become an **outstanding** undergraduate Computer Science program that produces **international-minded** graduates who are **competent** in software engineering and have **entrepreneurial spirit** and **noble character**.



Mission

1. To conduct studies with the best technology and curriculum, supported by professional lecturer
2. To conduct research in Informatics to promote science and technology
3. To deliver science-and-technology-based society services to implement science and technology